RECOMMENDATION: IT IN THE COMPANY

Security of IP-based surveillance cameras

Network-compatible surveillance or web cameras pose a potential security risk as many other types of devices in the context of the Internet of Things (IoT). This is particularly due to the fact that the aspect of cyber security is a design objective which is not taken into account or is taken into account only secondarily when developing and operating these devices. Therefore, such cameras can become a security risk for the organisation's own infrastructure as well as for third parties.

In the past few years, there were numerous incidents in connection with networked and/or IP-based surveillance cameras, e.g.:

- 2013: In the course of the "Carbanak" campaign a Russian hacker group compromised several banks in different countries and obtained hundreds of millions. In the course of these attacks, surveillance cameras within financial institutions were compromised in order to spy on screen contents and keyboard input, identify employees for example via name badges/employee identity cards as a target for spear phishing as well as to find out habits and reactions of the employees.[1]
- 2014: The website Insecam made the video pictures and/or streams of 73,000 inadequately protected webcams (mainly from private fields of application) freely available.[2]
- 2015: The Conficker malware from 2008 infected a large number of body worn cameras of different police forces.[3]
- 2016: A large number of surveillance/web cameras compromised by the Mirai malware was used to perform one of the most massive DDoS attacks in history on the specialist journalist Bryan Krebs.[4]

The objective of this document is to give an overview of the fundamental best practices regarding the secure operation of these cameras in the business environment.

1 Product selection and procurement

Already when selecting the product, not only the price-performance ratio, but also IT security aspects should be taken into consideration. In this respect, the offered function-

1 http://newsroom.kaspersky.eu/de/texte/detail/article/der-grosse-bankraub-cybergang-carbanak-stiehlt-eine-milliarde-us-dollar-von-100-finanzinstitu
2 http://www.networkworld.com/article/2844283/microsoft-subnet/peeping-into-73-000-unsecured-security-cameras-thanks-to-default-passwords.html
3 http://www.goipower.com/?pageId=40
4 https://krebsonsecurity.com/2016/10/source-code-for-iot-botnet-mirai-released/

BSI publications on cyber security

ality of the product and the manufacturer's warranties in particular play an important role. As a matter of principle, it is not advisable to use cameras with a cloud concept. In this case, sensitive data is leaking via third parties (e.g. camera manufacturer) and is stored there for access via the Internet. The cameras should also be equipped with a cable connection to be able to avoid using Wi-Fi/WLAN, especially in critical areas of application, provided that the application conditions allow this. When using Wi-Fi/WLAN, the recommendations mentioned in chapter 5 must be observed for protection.

A fundamental objective to achieve the secure use of IP cameras is to minimise the number of possible points of attack. To keep them low right from the beginning, it is recommended to procure cameras which only implement the services / ports required for the specific intended purpose. As an alternative, it should be possible to deactivate unnecessary services. If this is not possible either, corresponding restrictions must be made on network level during the commissioning in order to prevent the unnecessary services from being used.

To ensure the confidential transmission of video and configuration data, the product should support an encryption-based protocol (e.g. SSL/TLS or SSH).

If required by the intended purpose, the cameras should provide a differentiated role/rights concept for different users.

Furthermore, the manufacturer must ensure that patches and/or updates are provided for a sufficiently long period of time. In most cases, this is described as end of service (EOS), but must not be confused with end of life (EOL) which refers to the end of production and sale of a product.

2 Installation and initial operation

Not only when procuring, but also when initially operating IP cameras, there are recommendations for secure use. In general, the following applies: Embedded web servers, such as in the case of surveillance cameras, are typically not suitable to be made fully accessible via the Internet.

During the initial configuration of the camera, adequately secure passwords should be used. In addition to this, it is recommended to use alternative authentication mechanisms, such as certificate-based authentication. Furthermore, camera services which are not needed in this step should be deactivated. This applies in particular to chronically insecure services, such as Telnet or SNMPv1/v2.

In general, it applies that connections to the Internet initiated by the camera should be blocked. Valid targets, such as update servers of the manufacturer, storage location of the video data and management system can be configured as exceptions in the firewall. Whether and how the cameras have to contact the servers of the manufacturer in order to check the availability of updates should be researched in the product documentation.

Direct accessibility of the camera (e.g. by means of port forwarding on a router) should be avoided. If it is necessary that the cameras can be accessed from the outside (i.e. coming in from the Internet), this should be performed only with adequate authentication. **Therefore, it is essential to enable access from the outside via Telnet (port 23) under no circumstances and to enable access via SSH (port 22) only if it is protected with adequately secure individual passwords.** A higher level of security can be achieved if the access is not protected via user name and password, but by a software certificate. For communications to the outside world, do not use one of the ports used by default (23, 1023, 2323) but a random value in the range from 10000 to 65535.

If necessary, the remote access can also be protected by using VPN. This can, for example, be useful if the product itself does not provide any encrypted transmissions or authentication mechanisms. When using VPN, it must be ensured that sufficiently strong cryptographic procedures and corresponding key lengths are used.

It is also recommended to operate the cameras in a separate physical network area and/or within a separate virtual local area network (VLAN) in order to prevent lateral spreading if the cameras are compromised.

Depending on the application site of the cameras, physical access protection should be implemented. This does not only protect against vandalism, but also against modifications of the configuration which are often made possible by resetting the product to the factory configuration.

3 Operation phase

During the operation of the surveillance cameras, it should be checked at regular intervals whether new updates/patches are available for installation. In addition to the firmware of the cameras, third-party components, such as administration or management software, should be checked for up-to-dateness. If new updates are available, they must be installed in a timely manner.

It is recommended to check the communications (incoming and outgoing connections) for abnormalities at regular intervals. In this respect, log files of firewalls can provide precise information about with whom the camera wants to communicate via which service and whether these connections are allowed or blocked. Moreover, the cameras or the related administration or management software can also provide information as to whether the camera is used as expected.

Current malware on surveillance cameras and other IoT devices often only works in the main memory instead of persistently settling in the system. Therefore, it is advisable to regularly restart such cameras. This can clean an infection, although it cannot protect against re-infection.

4 Summary of the safeguards

- Avoiding unprotected accessibility via the Internet
- Restricting outgoing communications by means of a firewall
- Using self-defined, adequately strong passwords
- Allowing remote access via VPN only
- Activating only the services needed
- Communicating only in encrypted form
- Observing the EOS period
- Use of sufficiently strong authentication mechanisms
- Using network separation
- Installing updates in a timely manner
- Monitoring of communications (log files)

- Avoiding cloud concepts
- Avoiding Wi-Fi/WLAN in critical areas
- Optional use of rights and role concepts
- Optional use of physical access protection

5 Additional information

The following recommendations of the Alliance for Cyber Security as well as the BSI Technical Guidelines and the BSI-Standards zur Internet-Sicherheit (ISi-Reihe) [BSI standards for Internet security (ISi series)] provide additional information and describe recommendations for implementing the safeguards mentioned above:

- Anforderungen an netzwerkfähige Industriekomponenten (Requirements for network-compatible industrial components)[5]

  In addition to network-compatible industrial components, this recommendation can also be applied to a large number of IoT devices. In particular, this document also describes requirements for the manufacturer and/or integrator.

- Sichere Passwörter in Embedded Devices v1.0 (Secure passwords in embedded devices v1.0)[6]

  This recommendation describes the general problem of hard-coded access data in embedded devices which also include surveillance cameras. In this document, recommendations are given for manufacturers, integrators and operators.

- Rohde & Schwarz SIT GmbH: Checkliste Netzwerksicherheit (Checklist for network security)[7]

  This recommendation describes how the gateway to the Internet can be protected and gives recommendations how a network can be segmented for example by means of VLANs.

- BSI TR-02102 Kryptographische Verfahren: Empfehlungen und Schlüssellängen [Cryptographic Procedures: Recommendations and Key Lengths][8]

  Among other things, the Technical Guideline gives recommendations for the use of cryptographic procedures for TLS, VPN and SSH.

- BSI-Standards zur Internet-Sicherheit (ISi-Reihe) [BSI standards for Internet security (ISi series)][9]

  The ISi series deals with relevant topics, such as secure connection of local networks to the Internet (ISi-LANA), wireless LAN (ISi-WLAN) and virtual private network (ISi-VPN).

5 https://www.allianz-fuer-cybersicherheit.de/ACS/DE/_/downloads/BSI-CS_067.pdf
6 https://www.allianz-fuer-cybersicherheit.de/ACS/DE/_/downloads/BSI-CS_069.pdf
7 https://www.allianz-fuer-cybersicherheit.de/ACS/DE/_/partner/Partnerbeitrag_Rohde-Schwarz.html
8 https://www.bsi.bund.de/DE/Publikationen/TechnischeRichtlinien/tr02102/index_htm.html
9 https://www.bsi.bund.de/DE/Themen/StandardsKriterien/ISi-Reihe/ISi-Reihe_node.html

From IT-Grundschutz, module M 3.407 “Embedded system” in particular must be used. Moreover, the following modules and safeguards from IT-Grundschutz provide additional information and describe recommendations for implementing the safeguards mentioned above:

- B 3.407 Eingebettetes System (English version: M 3.407 Embedded system)[10]
- B 4.6 WLAN (English version: M 4.6 WLAN)[11]
- M 2.8 Vergabe von Zugriffsrechten (English version: S 2.8 Assignment of access rights)[12]
- M 2.11 Regelung des Passwortgebrauchs (English version: S 2.11 Provisions governing the use of passwords)[13]
- M 2.109 Rechtevergabe für den Fernzugriff (English version: S 2.109 Assigning rights for remote access)[14]
- M 2.273 Zeitnahes Einspielen sicherheitsrelevanter Patches und Updates (English version: S 2.273 Prompt installation of security-relevant patches and updates)[15]
- M 2.384 Auswahl geeigneter Kryptoverfahren für WLAN (English version: S 2.384 Selection of suitable crypto-methods for WLAN)[16]
- M 2.417 Planung der technischen VPN-Realisierung (English version: S2.417 Planning the technical VPN implementation)[17]
- M 2.555 Entwicklung eines Authentisierungskonzeptes für Anwendungen (English version: S 2.555 Developing an authentication concept for applications)[18]
- M 4.7 Änderung voreingestellter Passwörter (English version: S 4.7 Change of preset passwords)[19]
- M 4.488 Deaktivieren nicht benutzter Schnittstellen und Dienste bei eingebetteten Systemen (English version: S 4.488 Deactivating unused interfaces and services with embedded systems)[20]
- M 5.61 Geeignete physische Segmentierung (English version: S 5.61 Suitable physical segmentation)[21]
- M 5.62 Geeignete logische Segmentierung (English version: S 5.62 Suitable logical segmentation)[22]
- M 5.77 Bildung von Teilnetzen (English version: S 5.77 Establishment of subnetworks)[23]

By means of the BSI publications, the Federal Office for Information Security (BSI) publishes documents about current topics in the field of cyber security. Comments and advice from readers can be sent to **info@cyber-allianz.de**.

10 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/baust/b03/b03407.html
11 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/baust/b04/b04006.html
12 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02008.html
13 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02011.html
14 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02109.html
15 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02273.html
16 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02384.html
17 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02417.html
18 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m02/m02555.html
19 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m04/m04007.html
20 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m04/m04488.html
21 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m05/m05061.html
22 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m05/m05062.html
23 https://www.bsi.bund.de/DE/Themen/ITGrundschutz/ITGrundschutzKataloge/Inhalt/_content/m/m05/m05077.html